任务 1：数据库与查询条件基础说明（3 分）

1. 页面输入与数据库查询的关联

网站的用户登录、信息查询、数据展示等功能，本质是**用户输入条件 → 数据库查询 → 返回结果**的业务流程。

以用户登录场景为例：用户输入用户名和密码，系统将输入内容拼接成 SQL 查询语句，到数据库中验证是否存在匹配记录，再返回登录成功 / 失败结果。

2. 最小业务链路

用户输入 → 拼接 SQL 语句 → 数据库执行查询 → 页面返回结果

3. 用户输入进入查询条件的方式

后端代码直接将用户输入的字符串**无过滤、无转义**拼接到 SQL 语句中，输入内容成为 SQL 语句的一部分。

示例伪代码：

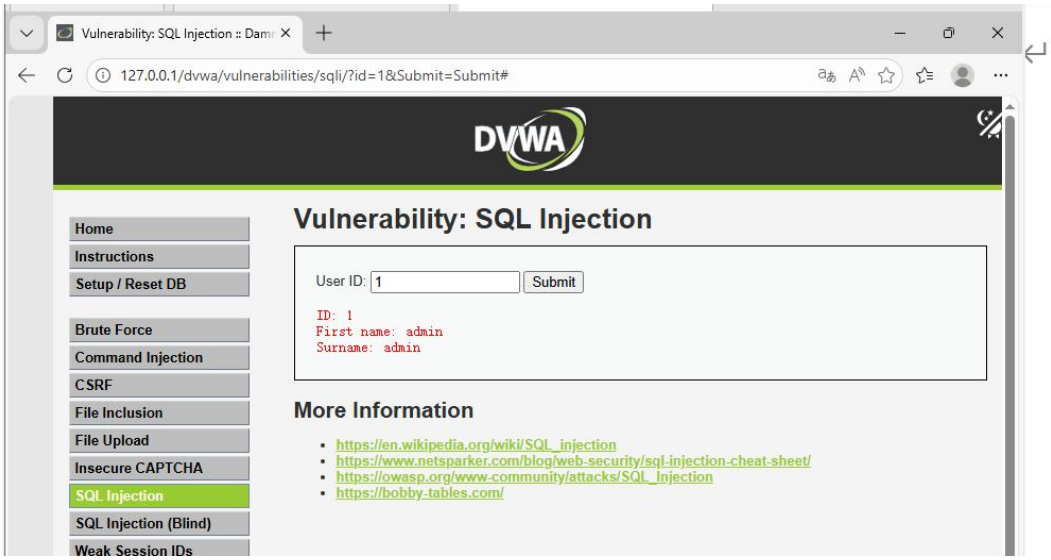
已生成代码

用户输入的 id 值直接嵌入查询语句。

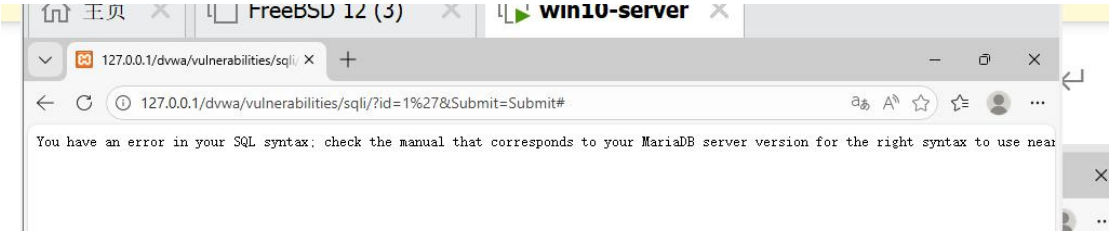
4. SQL 注入的可能性来源

输入未做安全处理，直接参与 SQL 结构拼接，**用户可通过构造特殊输入，改变原本的查询逻辑**，让数据库执行恶意指令，这就是 SQL 注入的核心前提。

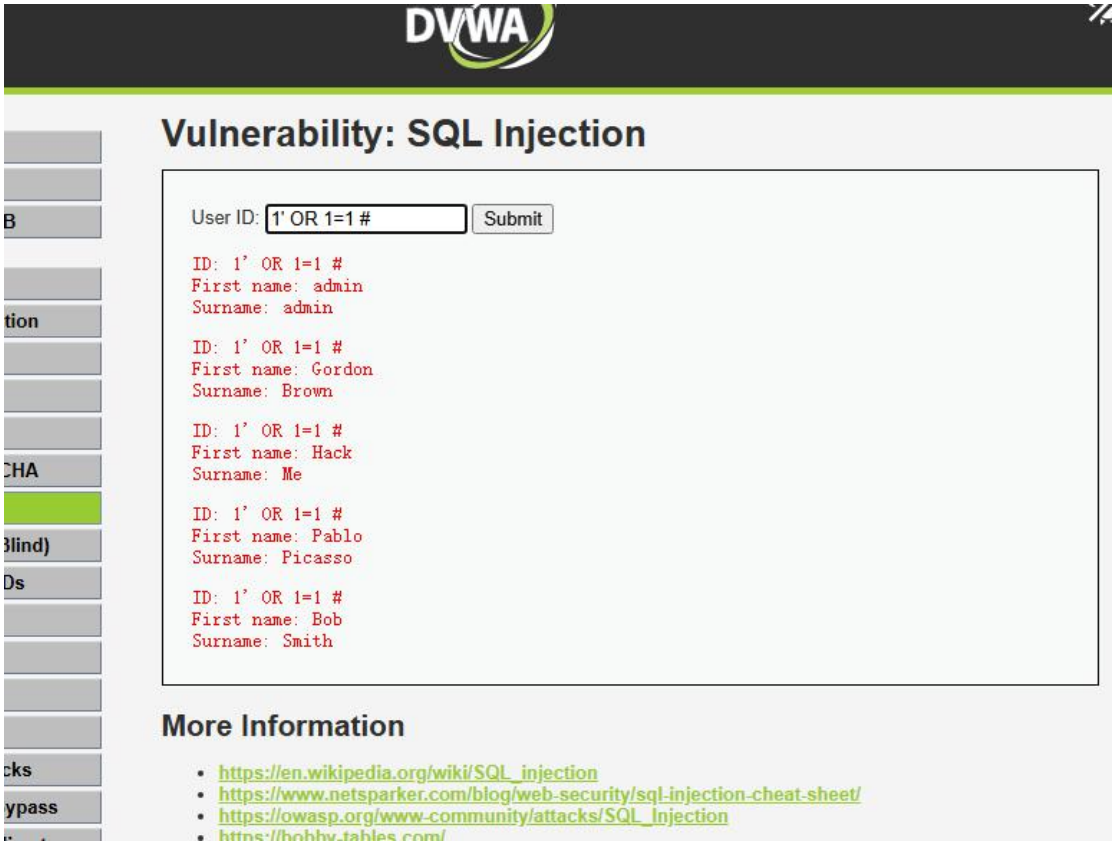
任务 2：DVWA SQL Injection Low 现象记录（4 分）



- **这是正常的业务查询行为，仅返回了 ID 匹配的单条数据。**



单引号被直接拼入 SQL 语句，破坏了语法结构，证明此处存在 SQL 注入漏洞。



恶意输入篡改了 SQL 逻辑，使查询条件恒成立，成功实现了 SQL 注入攻击。

任务 3：机制分析与差异比较（4.5 分）

1. 完整执行链条

输入 → 拼接 → 解析 → 执行 → 回显 / 行为差异

2. 根因判断

根因是**查询结构被污染**，不是字符本身危险。单引号、OR 等字符正常使用无危害，只有被拼入 SQL 结构、改变语法时才形成漏洞。

3. Low 与 Medium 差异

- Low：无任何防护，输入直接拼接，可直接注入。
- Medium：对单引号转义、简单过滤，未解决结构污染，仍可绕过。

4. 普通注入与盲注差异

- 普通 SQL 注入：页面**直接回显数据**，可直接查看结果。
- Blind SQL 注入：页面**不返回具体数据**，仅返回成功 / 失败，需用布尔或时间延迟推理内容。

5. 强制判断题

1. SQL 注入根因：**B. 输入进入了不该进入的查询结构**
   理由：漏洞源于输入参与构造 SQL 结构，而非包含危险字符。
2. 盲注与普通注入差异：**B. 证据形式不同**
   理由：根因都是结构被污染，仅回显方式、证据获取形式不同

任务 4：SQL 注入防护清单与解释（3.5 分）

1. 参数化查询（预编译）
   - 解决：从根源阻断输入参与 SQL 结构构造。
   - 控制层级：**根因控制**
   - 不可替代：不能代替输入校验，需配合业务规则。
2. 输入校验
   - 解决：限制输入格式、长度、字符，拦截明显恶意内容。
   - 控制层级：**暴露面收敛**
   - 不可替代：不能代替参数化查询，仅为辅助防护。
3. 错误处理
   - 解决：关闭数据库详细错误回显，避免泄露结构信息。
   - 控制层级：**暴露面收敛**
   - 不可替代：不能阻止注入，仅减少攻击线索。
4. 最小权限
   - 解决：限制数据库账号权限，降低注入后危害。
   - 控制层级：**后果范围控制**
   - 不可替代：不能阻止注入，仅缩小攻击影响。

收口项 1：SQL 注入因果链/防护关系图（3 分）

环节	内容说明
输入点	DVWA SQL Injection 模块的 User ID 输入框，id 参数可控
查询构造	后端直接将用户输入拼接到 SQL 语句中：SELECT first_name, last_name FROM users WHERE id = '$id'
数据库解析 / 执行	数据库执行拼接后的完整 SQL 语句，恶意输入会篡改查询逻辑
结果差异 / 行为证据	正常输入返回单条数据；恶意输入返回全表数据或触发语法错误
根因判断	用户输入参与了 SQL 语句的结构构造，而非仅作为数据值使用
防护控制点 1	参数化查询：使用预编译语句，分离 SQL 指令与用户输入
防护控制点 2	输入校验：限制输入格式、长度，过滤特殊字符

收口项 2：学生自评表（2 分）

- **我本章最清楚的一点是什么？**

我最清楚的是 SQL 注入的核心成因：用户输入被直接拼进 SQL 语句，污染了查询结构，而不是输入里的特殊字符本身有问题。

- **我最容易混淆的一点是什么？**

我最容易混淆普通注入和盲注的区别，特别是盲注如何通过页面状态变化来推断数据的过程。

- **我本次作业中哪一段最需要教师复核？**

我觉得任务 3 里关于 SQL 注入根因和不同安全级别防护差异的分析，需要老师帮我看看理解是否到位。

- **如果重做一次，我会优先改哪一部分？**

我会优先补充盲注的实验和分析，让整个实验内容更完整。

收口项 3：AI 输出审核与人工复核记录（必做）

1. 任务 1 和任务三使用了 ai 辅助
2. 任务 2 是自己复核保留的
3. 修正了 AI 给出的注入语句格式，结合 DVWA 的实际执行效果，调整了注释符的使用方式，确保能正确篡改 SQL 逻辑
   补充了实验截图对应的现象说明，修正了 AI 对 “正常查询与注入结果差异” 的描述，使其与实际返回数据完全对应
4. 对照自己的三次实验截图（正常输入、报错、注入成功），逐一验证每个结论都有对应的现象支撑
   核对 SQL 语句拼接逻辑与数据库执行结果，确保 “条件恒成立→返回全表数据” 的因果链完整